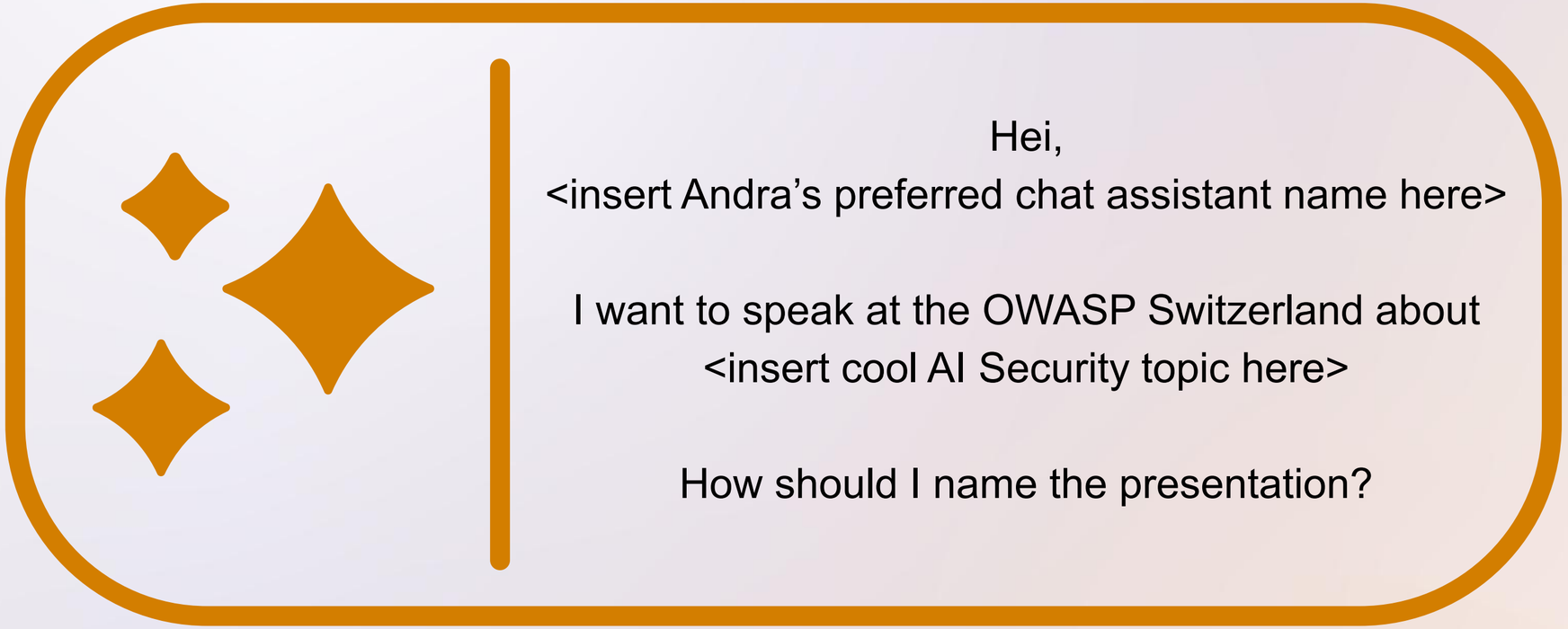
OWASP Switzerland 25th Edition

From Tool to Teammate: Making AI a Strategic Partner in Cyber Defense

Andra-Irina Vasile



Authorized external review only. Do not copy, distribute, or present without express written consent from author.



Authorized external review only. Do not copy, distribute, or present without express written consent from author.



Five questions every cyber leader is asking:

1. Where does AI actually create value in my operations?
2. Where will it create new failure modes I do not yet see?
3. How do I protect my team's skills and accountability while integrating it?
4. How do I keep humans meaningfully in the loop, without losing the speed advantage?
5. How can leadership balance AI security risks while allowing innovation and efficiency?

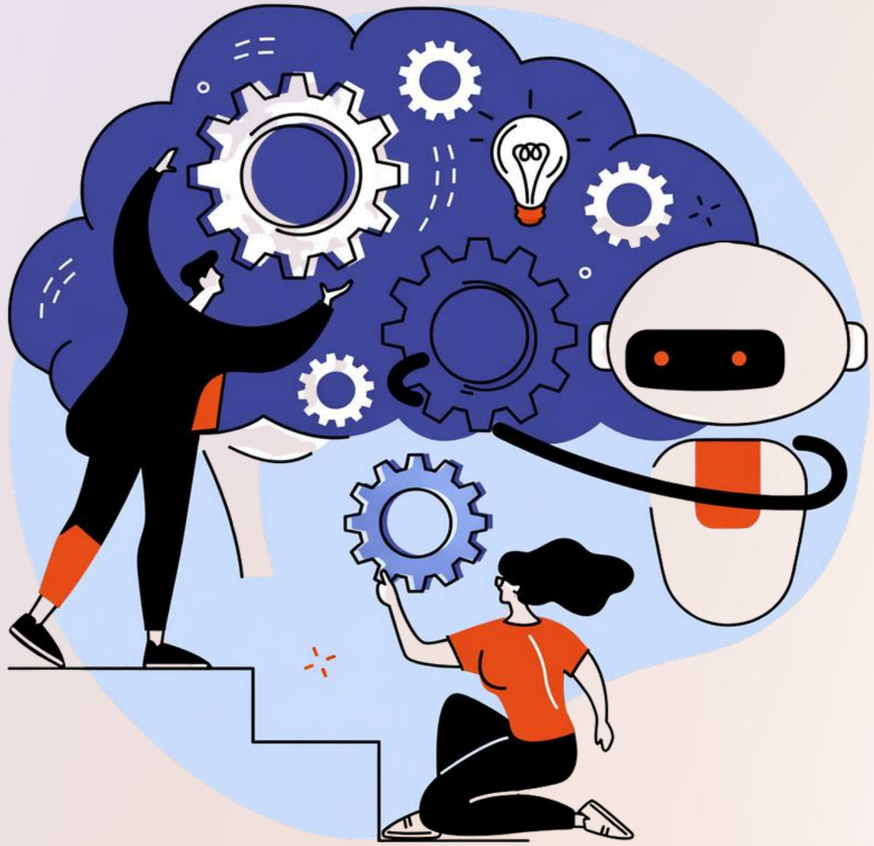
Authorized external review only. Do not copy, distribute, or present without express written consent from author.

My BIAS: Teammate model

AI does the work that scales.

The human does the work that requires judgement.

Clarity of roles



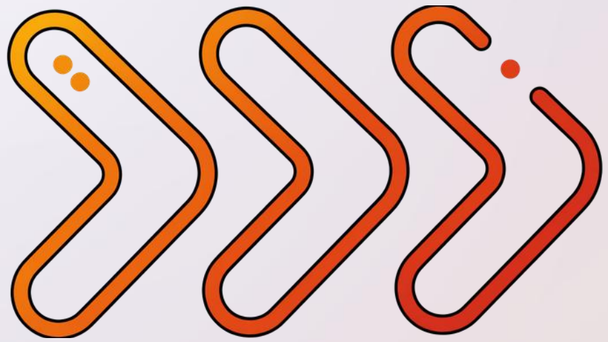
Authorized external review only. Do not copy, distribute, or present without express written consent from author.

The framing shift

Tool

Something you deploy, operate

- Measured by utilization
- Procured by features
- Governed by compliance
- Trained by reading the manual



Teammate

Something you onboard, calibrate

- Measured by outcomes
- Procured by fit-with-team
- Governed by accountability
- Trained by collaboration

Authorized external review only. Do not copy, distribute, or present without express written consent from author.



“The goal is not to remove humans from cyber defense.

It is to remove the work that prevented humans from doing cyber defense.”

Authorized external review only. Do not copy, distribute, or present without express written consent from author.

Three persistent limitations

Signal fragmentation

External intelligence rarely correlates with enterprise exposure, asset criticality or security control effectiveness. The result is intelligence that is informative, but not actionable.

01

Operational friction

Teams struggle to translate insight into timely action across SIEM, EDR, SOAR, cloud, identity and vulnerability management platforms. Tools do not talk and workflows fragment.

02

Human bottlenecks

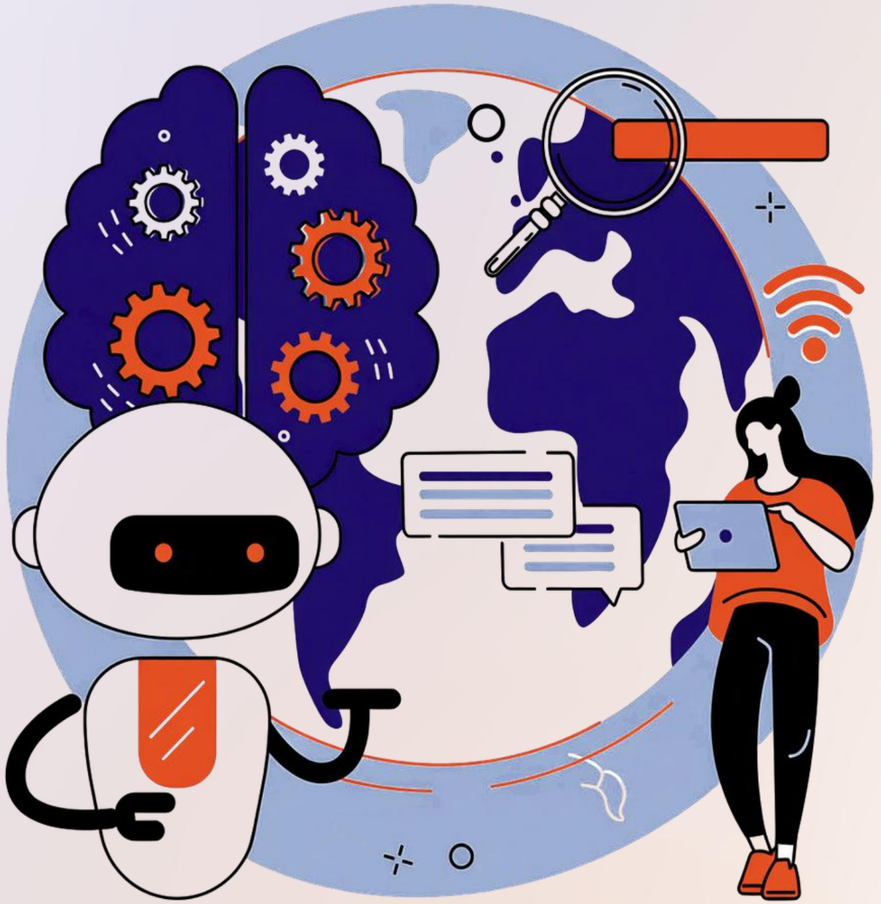
The volume of alerts, reports and telemetry overwhelms analyst capacity.

03

Authorized external review only. Do not copy, distribute, or present without express written consent from author.

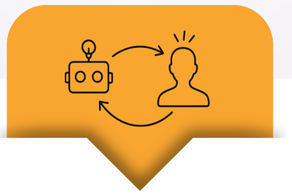
Where AI earns its seat

The modus operandi by function



Authorized external review only. Do not copy, distribute, or present without express written consent from author.

Governance Vocabulary: Human in/ on/ out of the loop



AI proposes

Human approves every action before it takes effect

e.g.: Isolating a production server, approving CTI publication, patching systems

Human in the loop

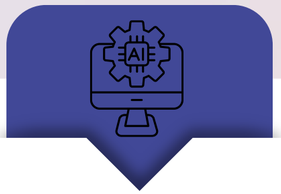


AI acts within scope

Human supervises and intervenes when needed

e.g.: auto-quarantining phishing, alert deduplication, dynamic rule tunning

Human on the loop



AI acts without real-time human review

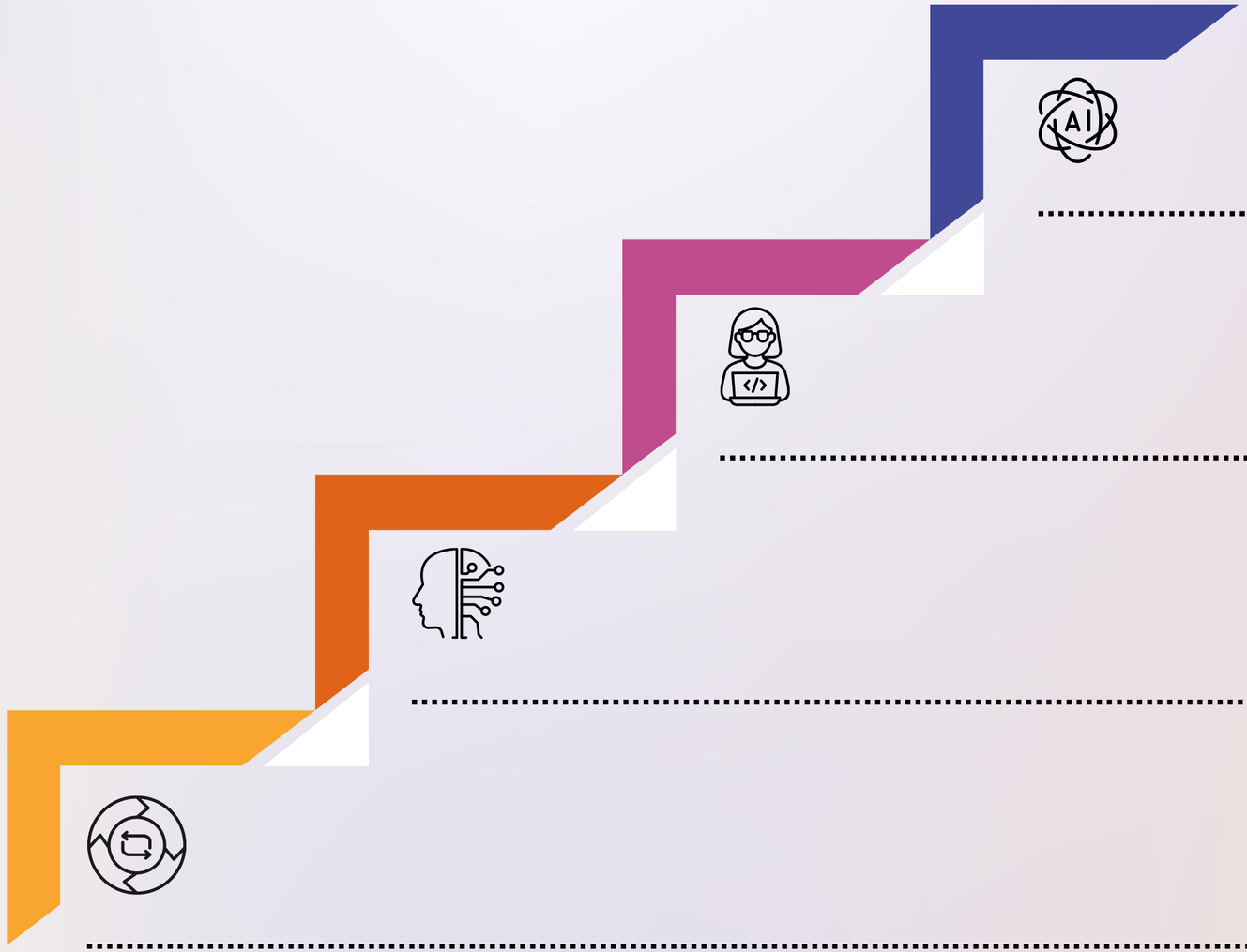
e.g.: spam filter with a user-report button, WAF signature blocking, auto-rate-limiting on bots

Human out of the loop

Authorized external review only. Do not copy, distribute, or present without express written consent from author.

Security Operations Center

Use case: Alert triage enrichment



AI sits

Upstream of the analyst's queue. Every alert that comes in gets enriched in the background with asset criticality, user behavior, threat-intel correlation, MITRE technique mapping.

Human sits

At the queue. The analyst opens an enriched alert that already includes a draft hypothesis with a confidence label. They will start at minute 5 instead of minute 35.

Handoff

The AI presents its recommendation alongside the raw evidence. The analyst decides.

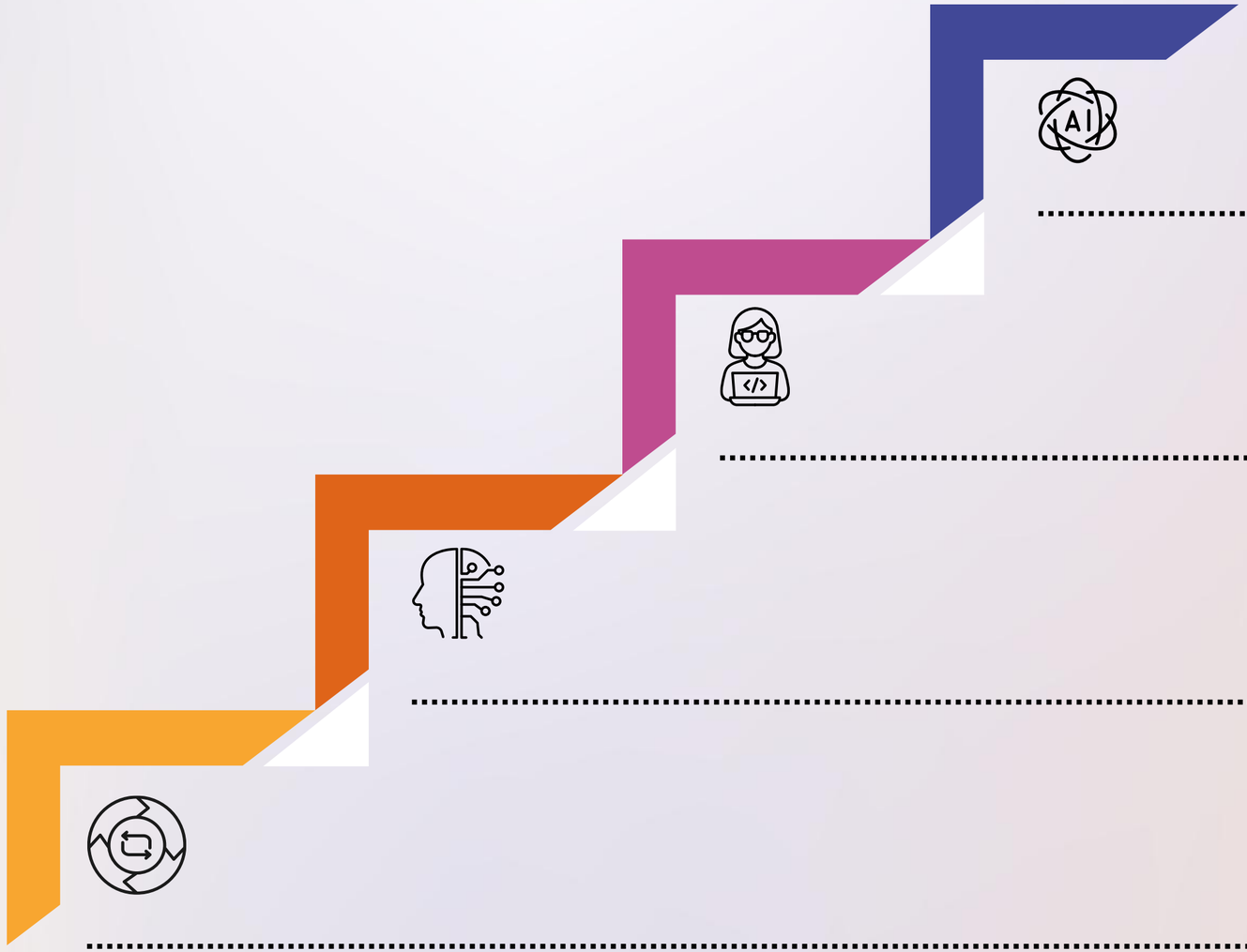
Loopback

What the analyst decides feeds back into the model's training. And critically, the dissent rate (how often analysts disagree with the AI) is itself a monitored metric as well.

Authorized external review only. Do not copy, distribute, or present without express written consent from author.

Threat Intelligence

Use case: multilingual source triage and organizational relevance



AI sits
On the ingestion side, it reads everything in every language. And on the consumption side, it takes a generic external threat report and answers the question: “What does this mean for us, specifically?”

Human sits

Owning two judgments AI cannot reliably make: source credibility and attribution. The analyst is the only signature on anything that leaves the team.

Handoff

AI produces structured extractions with confidence labels and provenance. The analyst validates and decides.

Loopback

When the analyst overrides AI's confidence label, that override gets logged. It feeds information like source-reputation training over time.

Authorized external review only. Do not copy, distribute, or present without express written consent from author.

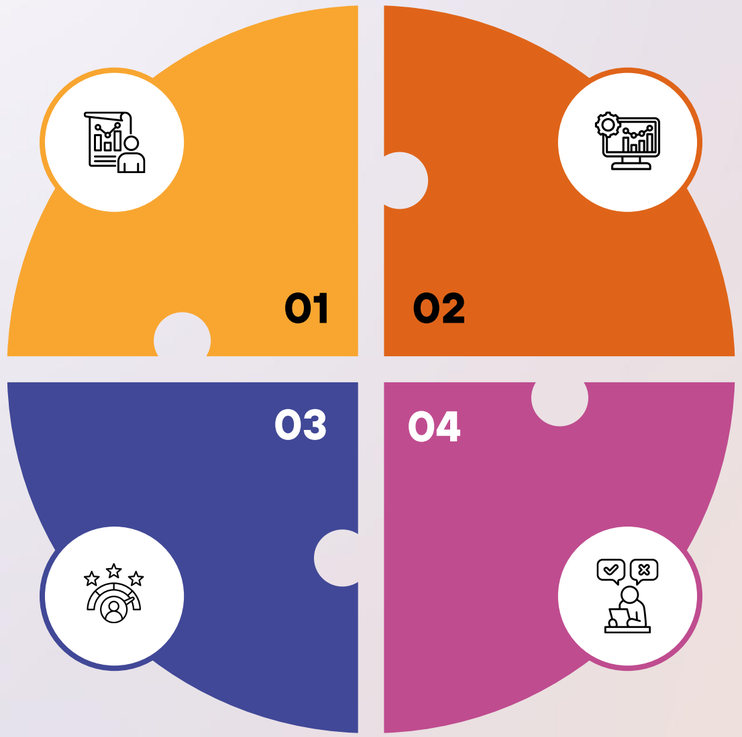
Autonomy is per action, not a single dial

Approval rule

HITL or HOTL? Required signature? Multi-party approval for destructive actions?

Confidence threshold

Numeric minimum for autonomous action. Below threshold = escalation. Tunable per action type.



Rollback capability

Can the action be undone? In how long? With what side effects? Consequence reversibility != technical reversibility

Audit logging

Every action logged: what, when, why, by which model, with what confidence, reviewed by whom? This is your AI operational hygiene.

Authorized external review only. Do not copy, distribute, or present without express written consent from author.

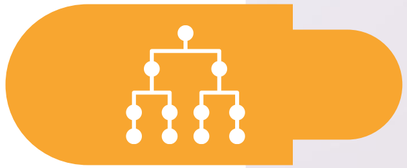
Two protocols to know

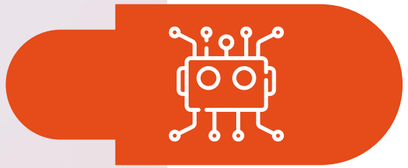
You need a coordinated defense system, not isolated AI tools

MCP (Model Context Protocol)

Enables AI agents to interact with tools, data and operational context. The standard for AI-to-tool communication; how an agent queries the EDR, pulls identity context or reads a playbook.

Developed and open-sourced by Anthropic





A2A (Agent2Agent Protocol)

An open standard for secure communication and coordination between AI agents across platforms. How the alert-triage agent hands off to the threat-hunt agent. Enables distributed intelligence.

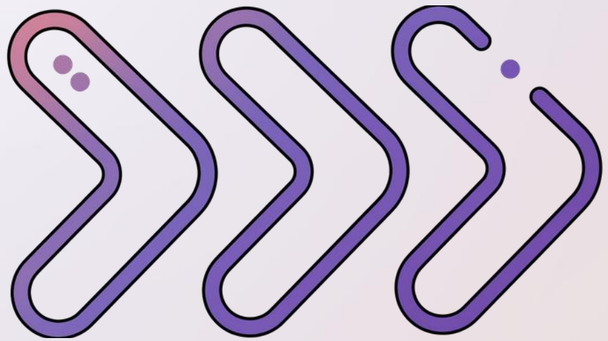
Developed by Google, now stewarded by the Linux Foundation

Authorized external review only. Do not copy, distribute, or present without express written consent from author.

Where are we heading to?

Assistive GenAI

Accelerates analyst interpretation through summarization, entity extraction, semantic search, alert enrichment and natural-language queries across security data.



Agentic AI

Goal-directed agents that plan and execute bounded actions like: remediating vulnerabilities, generating detection-rules, running hunt queries; all within governance constraints.

Authorized external review only. Do not copy, distribute, or present without express written consent from author.



If the decision is wrong who is held accountable?

The employee? The AI? The training data?

Authorized external review only. Do not copy, distribute, or present without express written consent from author.

Addressing the overconfidence attack surface

Dismissal of low-tier alerts

Overconfidence in AI-generated confidence scores can lead to the premature dismissal of low-priority alerts. In reality, these quiet anomalies can be the first breadcrumbs of a highly coordinated attack.



Scaling back human oversight

This reduction in manual verification amplifies exposure to systemic risks, most notably model drift and strategic adversarial manipulation.



Vulnerability to adversarial exploitation

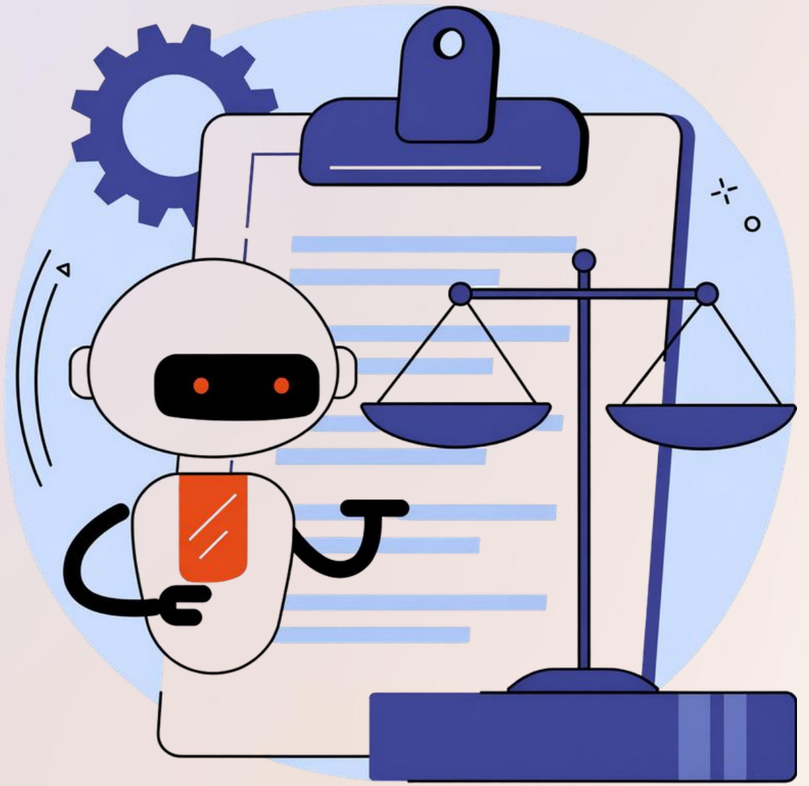
Attackers can exploit overconfidence by crafting adversarial inputs: data specifically tailored to trick machine learning models.



Authorized external review only. Do not copy, distribute, or present without express written consent from author.

Never trust an AI decision that you can not explain to your manager.

“Bias is the natural consequence of human-generated input.”



Authorized external review only. Do not copy, distribute, or present without express written consent from author.

AI-Ethics at Core

Transparency and accountability on top overseeing layer

Social responsibility

Addressing fairness and accountability in AI signals your organization's ethical commitment and protects its social standing.

Ethical scrutiny

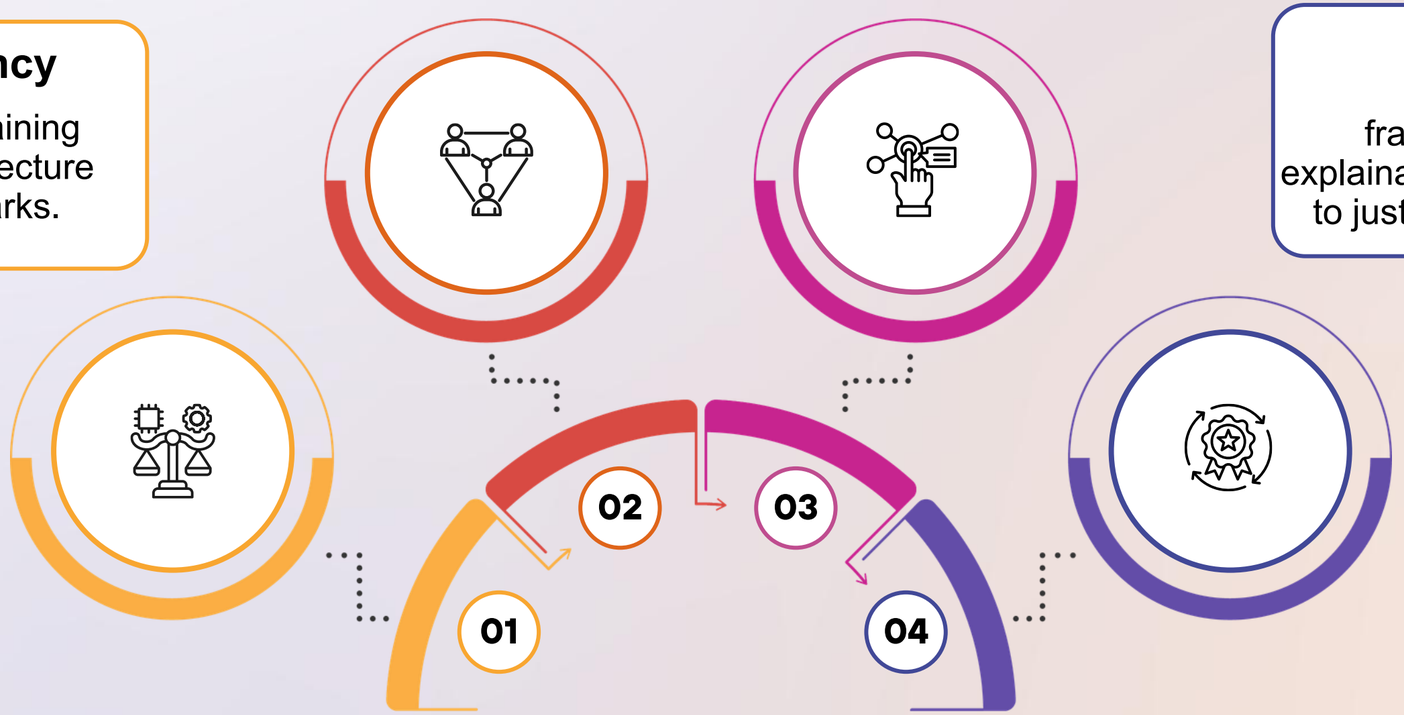
Addressing bias and unintended consequences keeps AI from perpetuating the inequalities it inherits from its training data.

Measured transparency

Evaluating disclosure of training data sources, model architecture and performance benchmarks.

Regulatory alignment

Operate within established framework and guidelines, e.g.: explainable AI provides the evidence to justify an action to stakeholders.



Authorized external review only. Do not copy, distribute, or present without express written consent from author.

SHAP (Shapley Additive ExPlanations) vs LIME (Local Interpretable Model-Agnostic Explanations)

Which one for which task?

SHAP

Best used for Auditing & Compliance

Helps analysts understand overall model behavior, not just one decision.

"What is the AI generally paying attention to?"

Analogy: a high-level architecture blueprint of the entire building



Lundberg & Lee, University of Washington, 2017 (built on Lloyd Shapley's values 1953)



LIME

Best used for Incident Response

Provides local explanations for individual predictions. For any single alert, shows which features most influenced the AI's decision.

"Why did the AI flag THIS alert?"

Analogy: A forensic photo of a single broken window.

Ribeiro, Singh and Guestrin at the University of Washington, 2016

Authorized external review only. Do not copy, distribute, or present without express written consent from author.

Explainable AI

Two blades of the same sword

Explainable AI as engineering practice

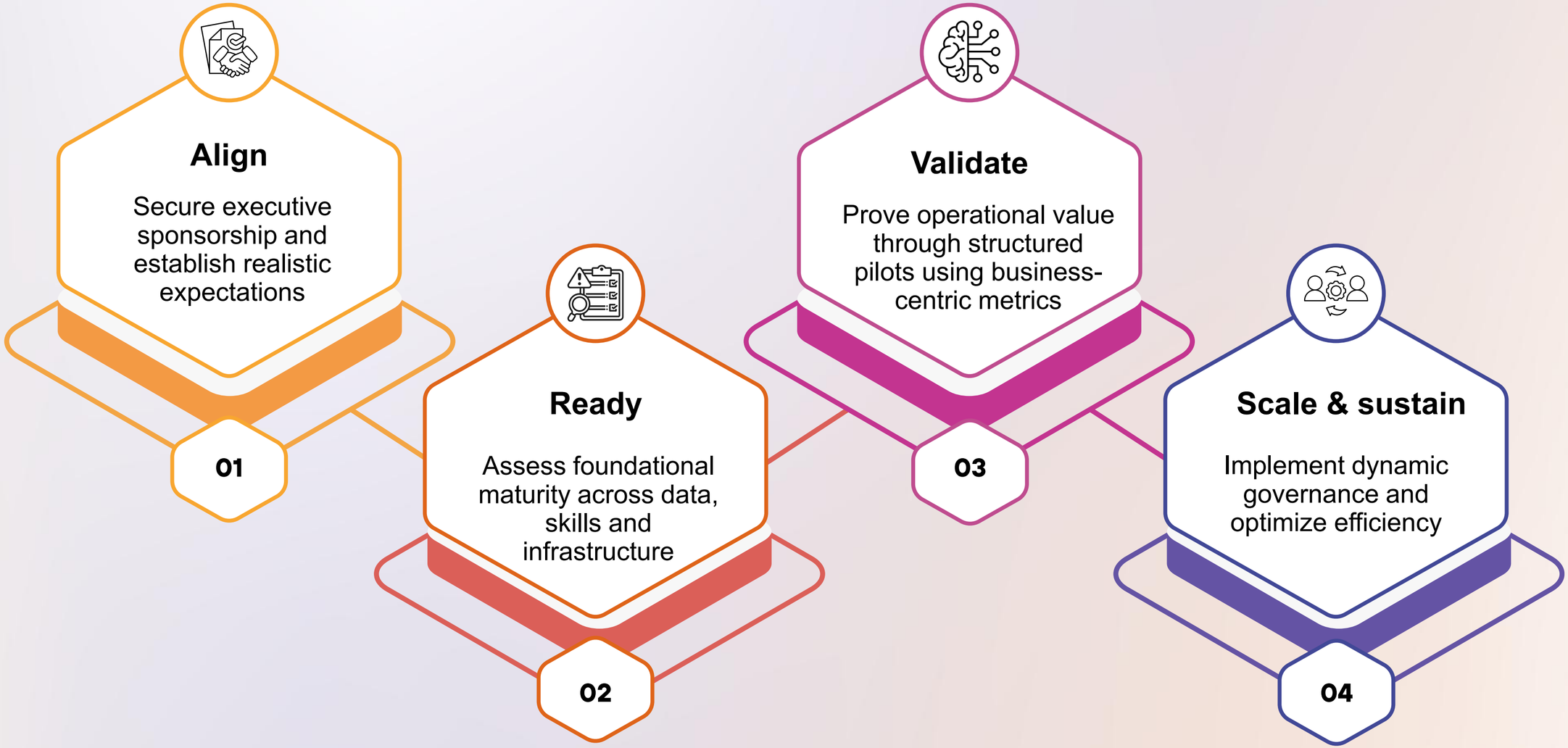
VS

Explainable AI as procurement practice via contractual deliverable

Authorized external review only. Do not copy, distribute, or present without express written consent from author.

Industry consensus for responsible AI adoption in Security

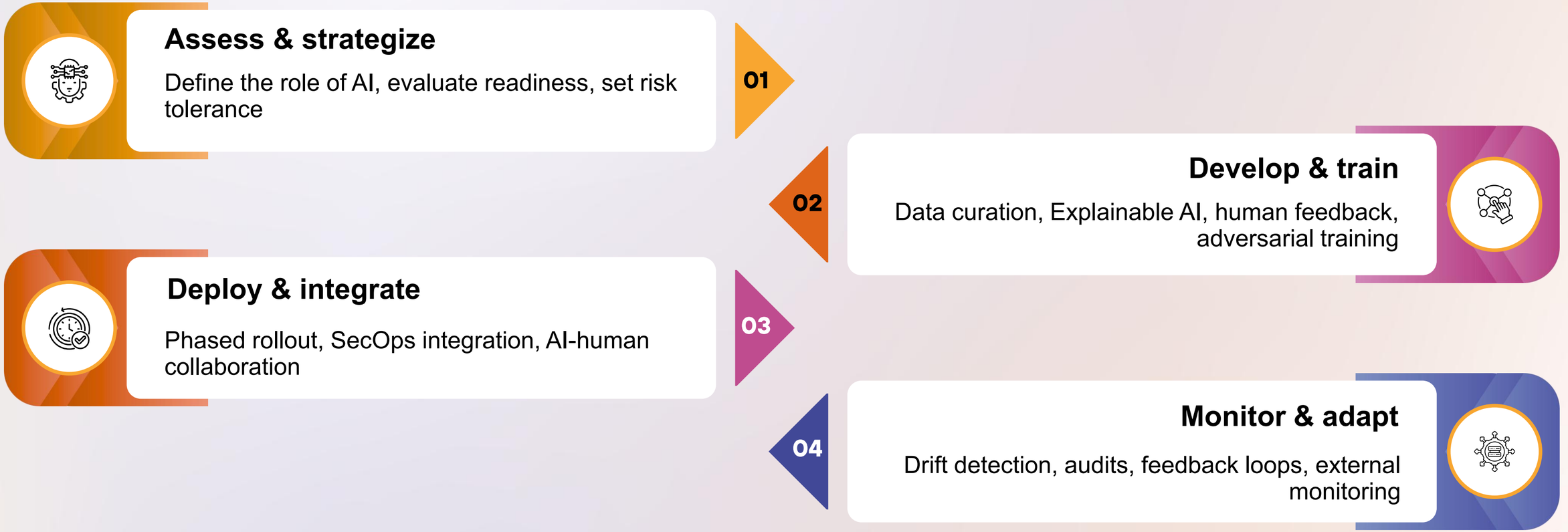
WEF/ KPMG May 2026



Authorized external review only. Do not copy, distribute, or present without express written consent from author.

Potential complementary operating framework

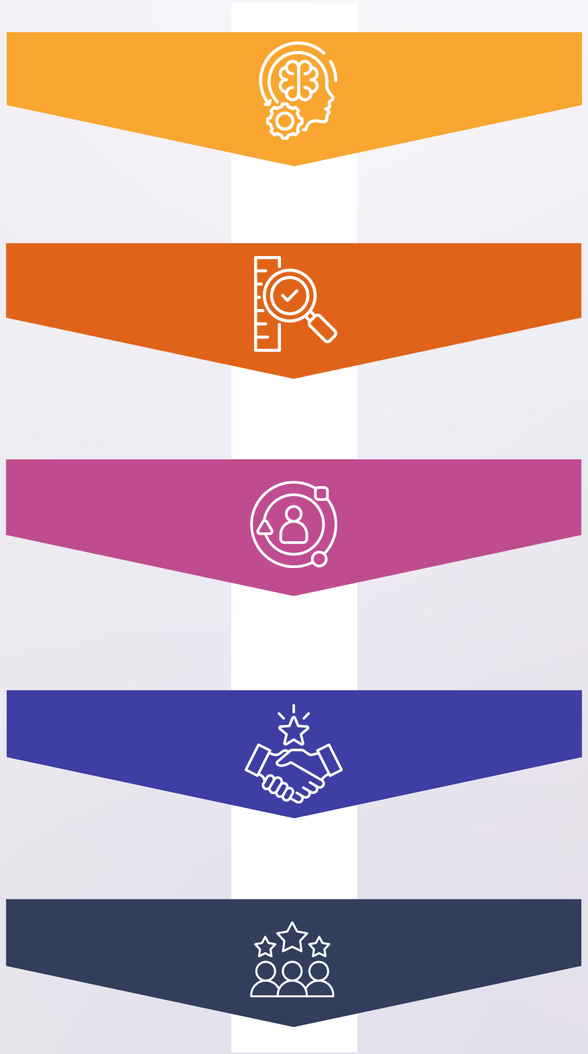
ISC2 proposal of a 4-phase model



Authorized external review only. Do not copy, distribute, or present without express written consent from author.

An adoption playbook

Five rules. Short to state. Uncomfortable to follow.



01 **Start with the “boring” stuff**

Alert enrichment, query translation, advisory summarization

02 **Measure outcomes, not adoption**

Mean times, false-positive rates, escape rate, dissent rate

03 **Protect the skills pipeline**

Rotate juniors, run scenario-based training

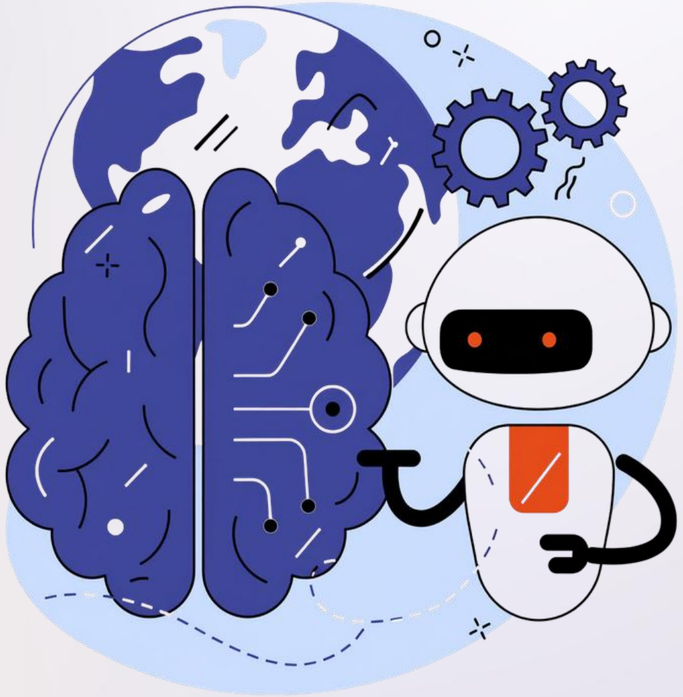
04 **Govern data flow before outputs**

Data-flow diagrams precede procurement; the vendor should be able to draw it on a whiteboard

05 **Treat AI like any other employee**

Job description, named supervisor, performance review, exit plan

Authorized external review only. Do not copy, distribute, or present without express written consent from author.



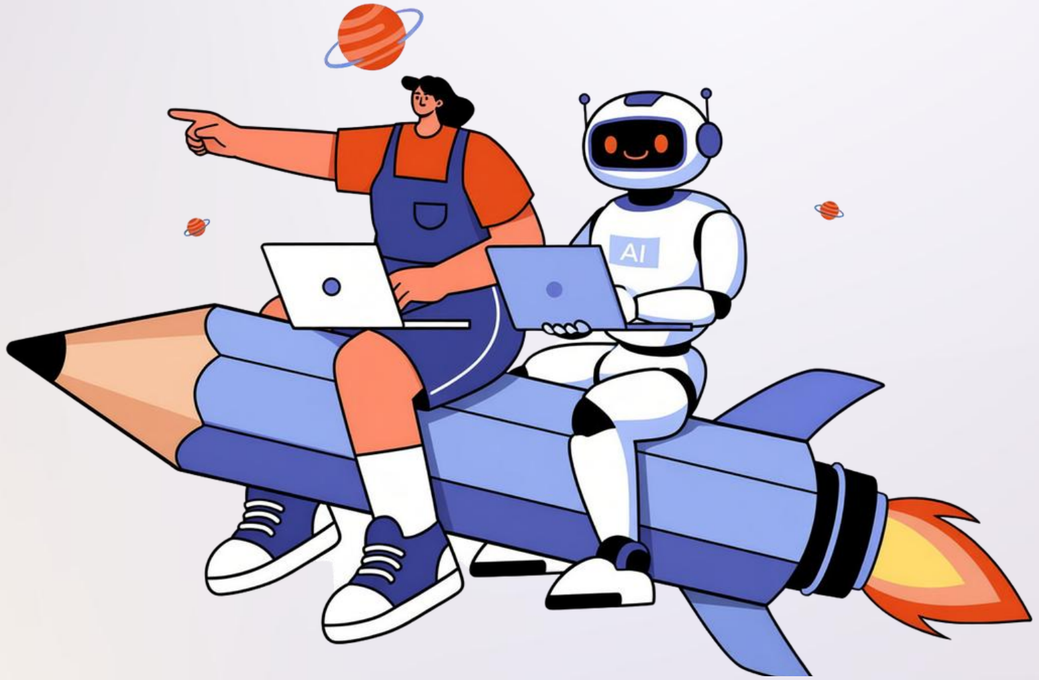
Resources:

ISC2: *Building an AI Strategy,* Official Training Material, 2026

Gartner, Inc.: *Feeds to Agents: How AI is Rewiring Cyberthreat Intelligence Operations*, Jonathan Nunez and Jaime Anderson, April 2026; *Transform Cybersecurity Operations with AI-Driven Threat Hunting,* Nahim Fazal, September 2025

World Economic Forum: *Empowering Defenders AI for Cybersecurity*, Whitepaper May 2026

Authorized external review only. Do not copy, distribute, or present without express written consent from author.



Thank you for listening!

Q & A

Get in touch on LinkedIn:

Authorized external review only. Do not copy, distribute, or present without express written consent from author.